

Initial Enumeration of the Domain

We are at the very beginning of our AD-focused penetration test against Inlanefreight. We have done some initial scoping and gotten a picture of what to expect from the customer via the scoping documents.

Setting Up

For this first portion of the test, we are starting on an attack host placed inside the network for us. This is a common setup that a client might select for us to perform an internal penetration test. A list of the types of setups a client may choose from includes:

- A penetration testing distro (typically Linux) as a virtual machine in their internal network that calls back to a jump host we control over VPN, and we can SSH into.
- A physical device plugged into an ethernet port that calls back to us over VPN.
- A physical presence at their office with our laptop plugged into an ethernet port.
- A Linux VM in either Azure or AWS with access to the internal network that we control via SSH key authentication and our public IP address whitelisted.
- VPN access into their internal network (a bit limiting because we will not be able to perform attacks such as LLMNR/NBT-NS Poisoning).
- From a corporate laptop connected to the client's VPN.
- On a managed workstation (typically Windows), physically sitting in their office with direct internet access or ability to pull in tools. They may also elect this option but with no direct internet access, local admin, and put endpoint protection into monitor mode so you can perform discovery.
- On a VDI (virtual desktop) accessed using Citrix or the like, with one of the above setups. The VDI for the managed workstation typically accessible over VPN either remotely or from a physical presence.

These are the most common setups I have seen, though a client may come up with another variation of or choose from a "grey box" approach where they give us just a list of in-scope IP addresses/CIDR network ranges and we have to plug in and do all discovery blindly using various techniques. Finally, they can choose either evasive or non-evasive (starting "quiet" and slowly getting louder to see what threshold we are detected at and then switch to a more aggressive approach).

They may also elect to have us start with no credentials or from the perspective of a standard domain user.

Our tasks to accomplish for this section are:

- Enumerate the internal network, identifying hosts, critical services, and potential foothold.
- This can include active and passive measures to identify users, hosts, and vulnerabilities able to take advantage of to further our access.
- Document any findings we come across for later use. Extremely important!

We will start from our Linux attack host without domain user credentials. It's a common thing to start a penetration test on organizations will wish to see what you can do from a blind perspective, such as this, before providing you with any credentials. It gives a more realistic look at what potential avenues an adversary would have to use to infiltrate the network. This could be what an attacker could do if they gain unauthorized access via the internet (i.e., a phishing attack), physical access to the network, wireless access from outside (if the wireless network touches the AD environment), or even a rogue employee. At the end of this phase, the customer may provide us with access to a domain-joined host or a set of credentials for a domain user and allow us to cover as much ground as possible.

Below are some of the key data points that we should be looking for at this time and noting down into our report. We will be saving scan/tool output to files whenever possible.

Key Data Points

Data Point	Description
AD Users	We are trying to enumerate valid user accounts we can target for password spraying.
AD Joined Computers	Key Computers include Domain Controllers, file servers, SQL servers, web servers, etc.
Key Services	Kerberos, NetBIOS, LDAP, DNS
Vulnerable Hosts and Services	Anything that can be a quick win. (a.k.a an easy host to exploit and gain a foothold)

TTPs

Enumerating an AD environment can be overwhelming if just approached without a plan. There is an abundance of tools and techniques available, but it's important to have a structured approach. We will be using a combination of tools and techniques to identify and exploit vulnerabilities in the AD environment.

and see what hosts and types of network traffic we can capture. This is particularly helpful if the assessment notice some [ARP](#) requests and replies, [MDNS](#), and other basic [layer two](#) packets (since we are on a switch in the current broadcast domain) some of which we can see below. This is a great start that gives us a few bits of the customer's network setup.

Scroll to the bottom, spawn the target, connect to the Linux attack host using [xfreerdp](#) and fire up Wireshark

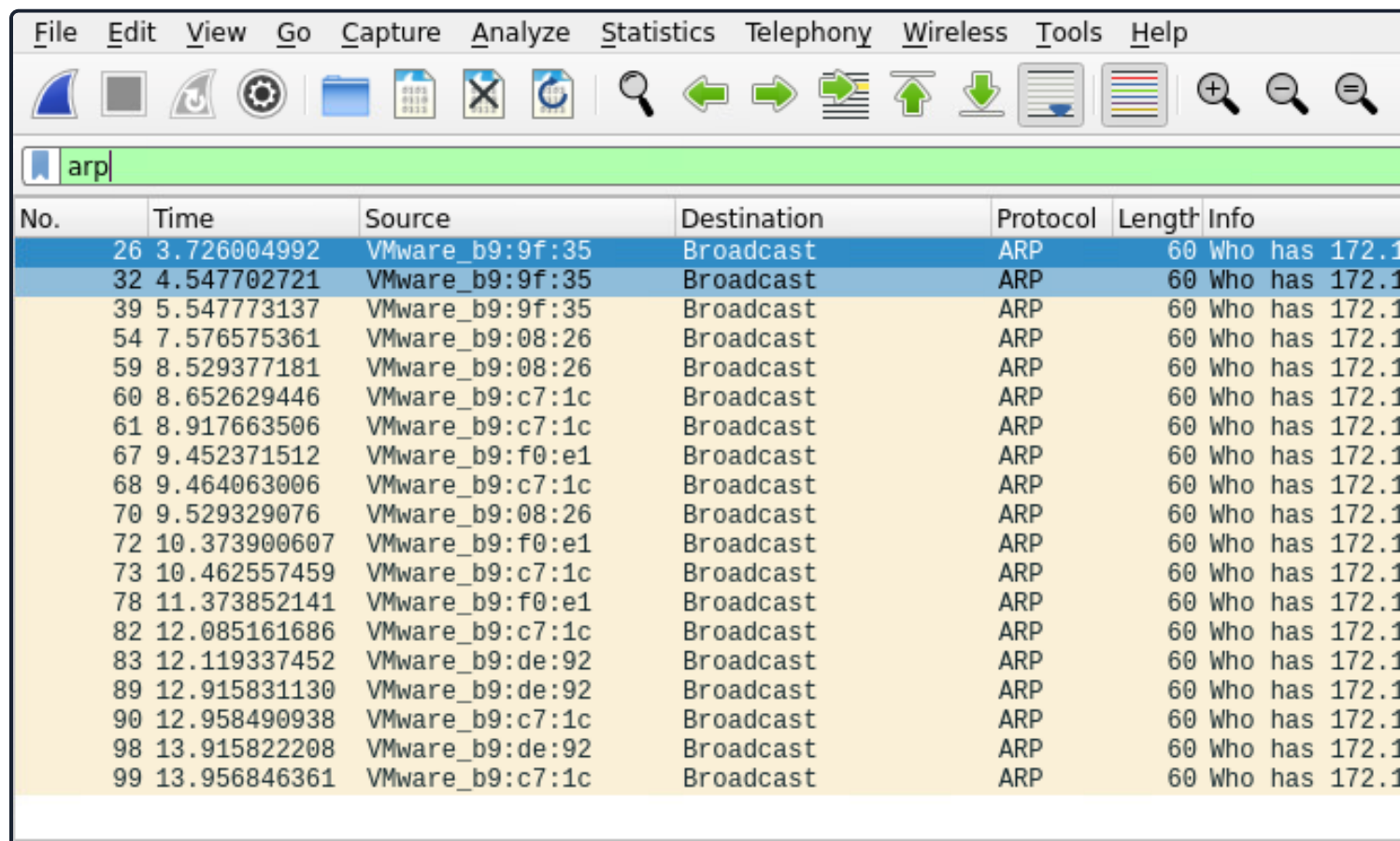
Start Wireshark on ea-attack01

Initial Enumeration of the Domain

```
[htb-student@ea-attack01]~  
└─$ sudo -E wireshark
```

```
11:28:20.487      Main Warn QStandardPaths: runtime directory '/run/user/1001' is not owned by the current user  
<SNIP>
```

Wireshark Output

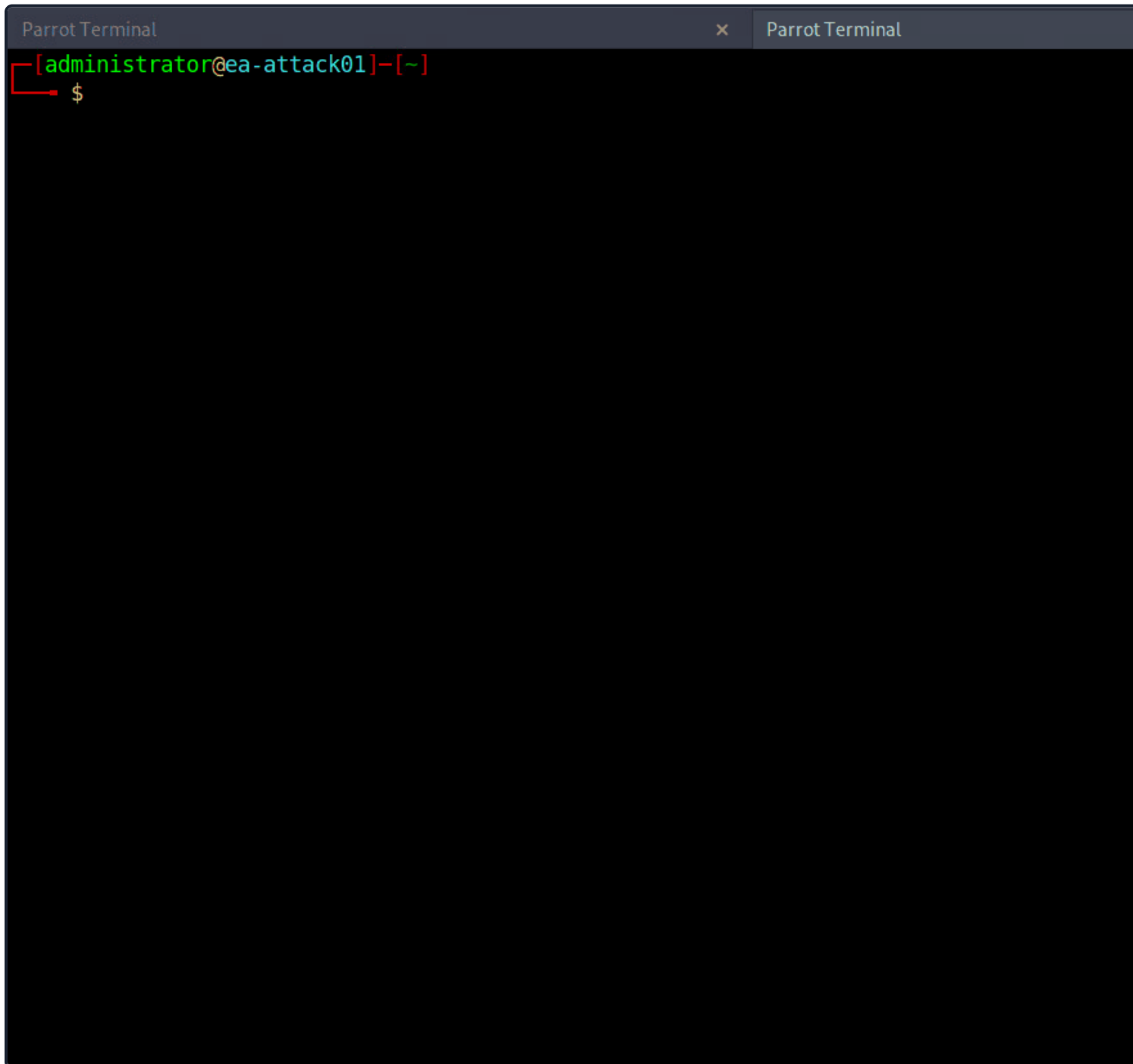


No.	Time	Source	Destination	Protocol	Length	Info
26	3.726004992	VMware_b9:9f:35	Broadcast	ARP	60	Who has 172.16.5.5
32	4.547702721	VMware_b9:9f:35	Broadcast	ARP	60	Who has 172.16.5.5
39	5.547773137	VMware_b9:9f:35	Broadcast	ARP	60	Who has 172.16.5.5
54	7.576575361	VMware_b9:08:26	Broadcast	ARP	60	Who has 172.16.5.5
59	8.529377181	VMware_b9:08:26	Broadcast	ARP	60	Who has 172.16.5.5
60	8.652629446	VMware_b9:c7:1c	Broadcast	ARP	60	Who has 172.16.5.5
61	8.917663506	VMware_b9:c7:1c	Broadcast	ARP	60	Who has 172.16.5.5
67	9.452371512	VMware_b9:f0:e1	Broadcast	ARP	60	Who has 172.16.5.5
68	9.464063006	VMware_b9:c7:1c	Broadcast	ARP	60	Who has 172.16.5.5
70	9.529329076	VMware_b9:08:26	Broadcast	ARP	60	Who has 172.16.5.5
72	10.373900607	VMware_b9:f0:e1	Broadcast	ARP	60	Who has 172.16.5.5
73	10.462557459	VMware_b9:c7:1c	Broadcast	ARP	60	Who has 172.16.5.5
78	11.373852141	VMware_b9:f0:e1	Broadcast	ARP	60	Who has 172.16.5.5
82	12.085161686	VMware_b9:c7:1c	Broadcast	ARP	60	Who has 172.16.5.5
83	12.119337452	VMware_b9:de:92	Broadcast	ARP	60	Who has 172.16.5.5
89	12.915831130	VMware_b9:de:92	Broadcast	ARP	60	Who has 172.16.5.5
90	12.958490938	VMware_b9:c7:1c	Broadcast	ARP	60	Who has 172.16.5.5
98	13.915822208	VMware_b9:de:92	Broadcast	ARP	60	Who has 172.16.5.5
99	13.956846361	VMware_b9:c7:1c	Broadcast	ARP	60	Who has 172.16.5.5

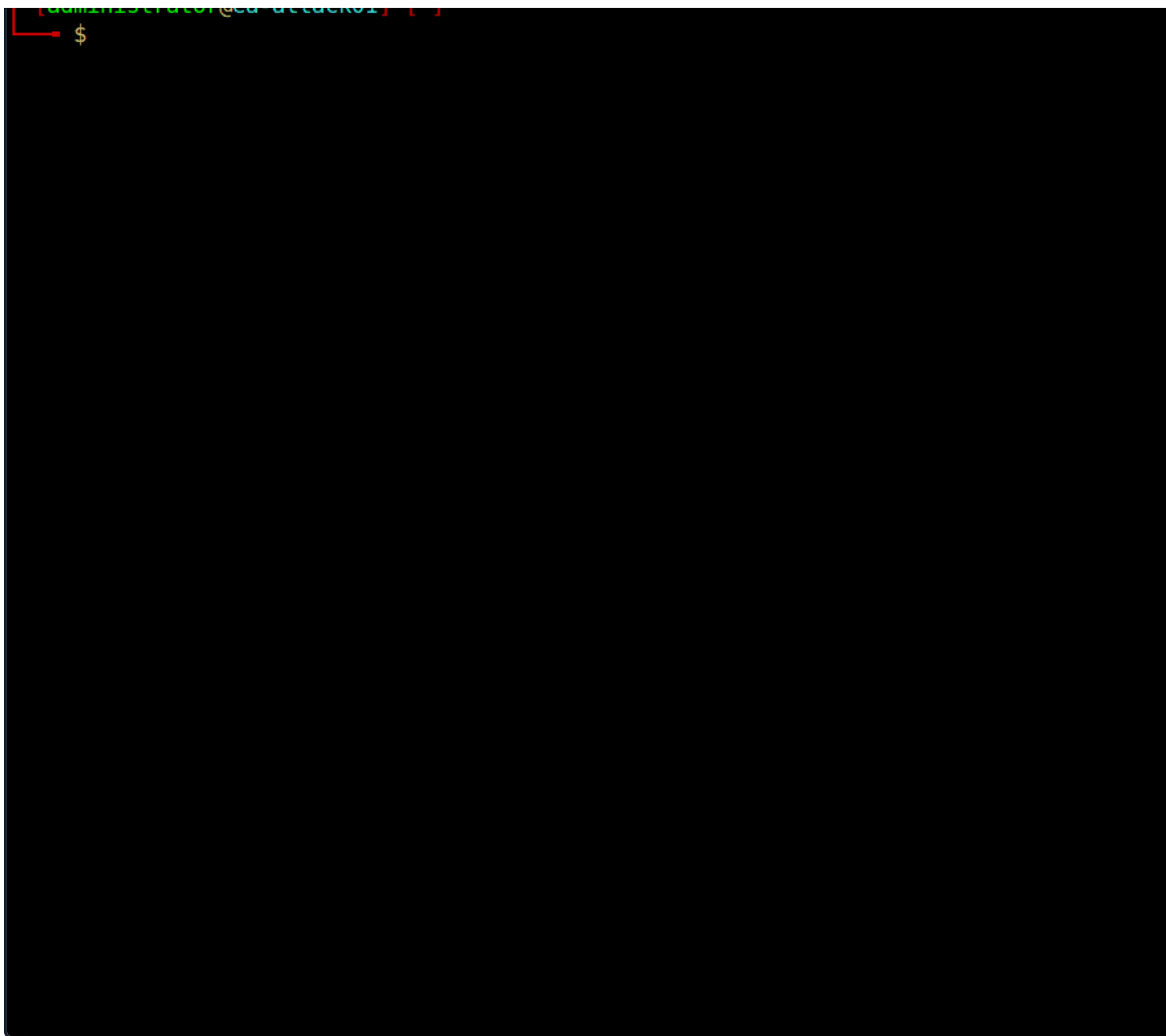
- ARP packets make us aware of the hosts: 172.16.5.5, 172.16.5.25 172.16.5.50, 172.16.5.125.

Initial Enumeration of the Domain

```
dbcyp0n@htb[/htb]$ sudo tcpdump -i ens224
```



There is no one right way to listen and capture network traffic. There are plenty of tools that can process network traffic. `tcpdump` are just a few of the easiest to use and most widely known. Depending on the host you are on, you may have a network monitoring tool built-in, such as `pktmon.exe`, which was added to all editions of Windows 10. As a note for future reference, you can save the PCAP traffic you capture. You can review it again later to look for more hints, and it makes for good documentation while writing your reports.



As we start Responder with passive analysis mode enabled, we will see requests flow in our session. Note the unique hosts not previously mentioned in our Wireshark captures. It's worth noting these down as we are looking for IPs and DNS hostnames.

Our passive checks have given us a few hosts to note down for a more in-depth enumeration. Now let's proceed starting with a quick ICMP sweep of the subnet using `fping`.

`Fping` provides us with a similar capability as the standard ping application in that it utilizes ICMP requests to interact with a host. Where `fping` shines is in its ability to issue ICMP packets against a list of multiple hosts. Also, it works in a round-robin fashion, querying hosts in a cyclical manner instead of waiting for multiple responses to return before moving on. These checks will help us determine if anything else is active on the internal network.

```
510 targets
  9 alive
501 unreachable
  0 unknown addresses

2004 timeouts (waiting for response)
2013 ICMP Echos sent
  9 ICMP Echo Replies received
2004 other ICMP received

0.029 ms (min round trip time)
0.396 ms (avg round trip time)
0.799 ms (max round trip time)
15.366 sec (elapsed real time)
```

The command above validates which hosts are active in the `/23` network and does it quietly instead of spamming the console for each IP in the target list. We can combine the successful results and the information we gleaned from the `ping` command with a more detailed scan with Nmap. From the `fping` command, we can see 9 "live hosts," including our attacker's IP.

Note: Scan results in the target network will differ from the command output in this section due to the size of the network. It is worth reproducing each example to practice how these tools work and note down every host that is live in the network.

Nmap Scanning

Now that we have a list of active hosts within our network, we can enumerate those hosts further. We are going to identify services each host is running, identify critical hosts such as `Domain Controllers` and `web servers`, and identify hosts to probe later. With our focus on AD, after doing a broad sweep, it would be wise of us to focus on services accompanying AD services, such as DNS, SMB, LDAP, and Kerberos name a few. Below is a quick example of how to run Nmap.

Code: `bash`

```
sudo nmap -v -A -iL hosts.txt -oN /home/htb-student/Documents/host-enum
```

The `-A` ([Aggressive scan options](#)) scan will perform several functions. One of the most important is a quick scan of ports to include web services, domain services, etc. For our `hosts.txt` file, some of our results from Response (we found the name and IP address), so to keep it simple, just the IP address was fed into `hosts.txt` for the scan.

NMAP Result Highlights

```
464/tcp open  kpasswd5?
593/tcp open  ncacn_http  Microsoft Windows RPC over HTTP 1.0
636/tcp open  ssl/ldap    Microsoft Windows Active Directory LDAP (Domain: INLANEFREIGHT)
<SNIP>
3268/tcp open  ldap        Microsoft Windows Active Directory LDAP (Domain: INLANEFREIGHT)
3269/tcp open  ssl/ldap    Microsoft Windows Active Directory LDAP (Domain: INLANEFREIGHT)
3389/tcp open  ms-wbt-server Microsoft Terminal Services
| rdp-ntlm-info:
|   Target_Name: INLANEFREIGHT
|   NetBIOS_Domain_Name: INLANEFREIGHT
|   NetBIOS_Computer_Name: ACADEMY-EA-DC01
|   DNS_Domain_Name: INLANEFREIGHT.LOCAL
|   DNS_Computer_Name: ACADEMY-EA-DC01.INLANEFREIGHT.LOCAL
|   DNS_Tree_Name: INLANEFREIGHT.LOCAL
|   Product_Version: 10.0.17763
|_  System_Time: 2022-04-04T15:12:45+00:00
<SNIP>
5357/tcp open  http        Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Service Unavailable
|_http-server-header: Microsoft-HTTPAPI/2.0
Service Info: Host: ACADEMY-EA-DC01; OS: Windows; CPE: cpe:/o:microsoft:windows
```

Our scans have provided us with the naming standard used by NetBIOS and DNS, we can see some hosts pointed us in the direction of the primary **Domain Controller** for the INLANEFREIGHT.LOCAL domain (ACADEMY-EA-DC01.INLANEFREIGHT.LOCAL). The results below show some interesting results surrounding a possibly current lab).

Initial Enumeration of the Domain

```
dbcyph0n@htb[/htb]$ nmap -A 172.16.5.100
```

```
Starting Nmap 7.92 ( https://nmap.org ) at 2022-04-08 13:42 EDT
```

```
Nmap scan report for 172.16.5.100
```

```
Host is up (0.071s latency).
```

```
Not shown: 989 closed tcp ports (conn-refused)
```

```
PORT      STATE SERVICE      VERSION
```

```
80/tcp    open  http         Microsoft IIS httpd 7.5
```

```
|_http-title: Site doesn't have a title (text/html).
```

```
|_http-server-header: Microsoft-IIS/7.5
```

```
|_http-methods:
```

```
|_ Potentially risky methods: TRACE
```

```
135/tcp   open  msrpc        Microsoft Windows RPC
```

```
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
```

```
443/tcp   open  https?
```

```
445/tcp   open  microsoft-ds Windows Server 2008 R2 Standard 7600 microsoft-ds
```

```
1433/tcp  open  ms-sql-s     Microsoft SQL Server 2008 R2 10.50.1600.00; RTM
```

```
|_nbstat: NetBIOS name: ACADEMY-EA-CTX1, NetBIOS user: <unknown>, NetBIOS MAC: 00:50:56:00:00:00
| smb-os-discovery:
|   OS: Windows Server 2008 R2 Standard 7600 (Windows Server 2008 R2 Standard 6.1)
|   OS CPE: cpe:/o:microsoft:windows_server_2008::-
|   Computer name: ACADEMY-EA-CTX1
|   NetBIOS computer name: ACADEMY-EA-CTX1\x00
|   Domain name: INLANEFREIGHT.LOCAL
|   Forest name: INLANEFREIGHT.LOCAL
|   FQDN: ACADEMY-EA-CTX1.INLANEFREIGHT.LOCAL
|_  System time: 2022-04-08T10:43:48-07:00
```

<SNIP>

We can see from the output above that we have a potential host running an outdated operating system (Windows Server 2008 R2 Standard 7600 based on the output). This is of interest to us since it means there are legacy operating systems running in the environment, which means there is potential for older exploits like EternalBlue, MS08-067, and others to work and provide us with a foothold. As weird as it sounds to have hosts running legacy software or end-of-life operating systems, it is still common in industrial environments. You will often have some process or equipment such as a production line or the HVAC building that has been in place for a long time. Taking equipment like that offline is costly and can hurt an organization, so legacy systems are often left in place. They will likely try to build a hard outer shell of Firewalls, IDS/IPS, and other monitoring and protection so that if you can find your way into one, it is a big deal and can be a quick and easy foothold. Before exploiting legacy systems, we should alert our client and get their approval in writing in case an attack results in system instability or brings a service offline. The client may prefer that we just observe, report, and move on without actively exploiting the system.

The results of these scans will clue us into where we will start looking for potential domain enumeration and user enumeration. We need to find our way to a domain user account. Looking at our results, we found several servers that had services running (e.g., MX01, WS01, etc.). Now that we know what exists and what services are running, we can poll those servers for users. Be sure to use the `-oA` flag as a best practice when performing Nmap scans. This will ensure that we get all the results in several formats for logging purposes and formats that can be manipulated and fed into other tools.

We need to be aware of what scans we run and how they work. Some of the Nmap scripted scans run actively on the host that could cause system instability or take it offline, causing issues for the customer or worse. For example, a scan against a network with devices such as sensors or logic controllers could potentially overload them and cause the industrial equipment causing a loss of product or capability. Take the time to understand the scans you use and the impact on the customer's environment.

We will most likely return to these results later for further enumeration, so don't forget about them. We need to

starting from an unauthenticated perspective. We can point Kerbrute at the DC we found earlier and feed it with a list of hosts and we will be provided with results letting us know if the accounts found are valid or not, which is a great tool for performing attacks such as password spraying, which we will cover in-depth later in this module.

To get started with Kerbrute, we can download [precompiled binaries](#) for the tool for testing from Linux, Windows, or macOS, or we can compile it ourselves. This is generally the best practice for any tool we introduce into a client environment. On the system of our choosing, we first clone the repo:

Cloning Kerbrute GitHub Repo

Initial Enumeration of the Domain

```
dbcyph0n@htb[/htb]$ sudo git clone https://github.com/ropnop/kerbrute.git

Cloning into 'kerbrute'...
remote: Enumerating objects: 845, done.
remote: Counting objects: 100% (47/47), done.
remote: Compressing objects: 100% (36/36), done.
remote: Total 845 (delta 18), reused 28 (delta 10), pack-reused 798
Receiving objects: 100% (845/845), 419.70 KiB | 2.72 MiB/s, done.
Resolving deltas: 100% (371/371), done.
```

Typing `make help` will show us the compiling options available.

Listing Compiling Options

Initial Enumeration of the Domain

```
dbcyph0n@htb[/htb]$ make help

help:          Show this help.
windows:      Make Windows x86 and x64 Binaries
linux:        Make Linux x86 and x64 Binaries
mac:          Make Darwin (Mac) x86 and x64 Binaries
clean:        Delete any binaries
all:          Make Windows, Linux and Mac x86/x64 Binaries
```

We can choose to compile just one binary or type `make all` and compile one each for use on Linux, Windows, and macOS (we will cover each in detail in a later module, but we will use the x86 and x64 version for each).

<SNIP>

The newly created `dist` directory will contain our compiled binaries.

Listing the Compiled Binaries in dist

Initial Enumeration of the Domain

```
dbcyph0n@htb[/htb]$ ls dist/
kerbrute_darwin_amd64  kerbrute_linux_386  kerbrute_linux_amd64  kerbrute_windows_386.
```

kerbrute_darwin_amd64 kerbrute_linux_386 kerbrute_linux_amd64 kerbrute_windows_386.exe

We can then test out the binary to make sure it works properly. We will be using the x64 version on the supplied VM, but we can also test it on the target environment.

Testing the kerbrute_linux_amd64 Binary

Initial Enumeration of the Domain

```

dbcyph0n@htb[/htb]$ ./kerbrute_linux_amd64

  --      --      --
 / /____ _ _ _ / / _ _ _ _ _ _ / / ____
 / // / _ \ _ _ / _ \ _ _ / // / / / _ \ _ \
 / ,< / _ / / / / / / / / / / / / / _ /
 / _ / | \ _ _ / / / _ _ / / _ _ , \ _ _ \ _ _ /

Version: dev (9cfb81e) - 02/17/22 - Ronnie Flathers @ropnop

This tool is designed to assist in quickly bruteforcing valid Active Directory accounts.
It is designed to be used on an internal Windows domain with access to one of the Domain Controllers.
Warning: failed Kerberos Pre-Auth counts as a failed login and WILL lock out accounts.

Usage:
  kerbrute [command]

<SNIP>

```

/ / _ _ _ _ _ _ _ _ / / _ _ _ _ _ _ _ _ / / _ _ _ _ _
 / / / / _ _ \ \ _ _ / _ _ \ \ _ _ / / / / / / _ _ / _ \
 / , < / _ _ / / / / _ / / / / / _ / / / _ / _ _ /
 / _ / | _ | \ _ _ _ / _ / _ / _ _ _ / _ / _ \ _ _ / \ _ _ / \ _ _ /

Version: dev (9cfb81e) - 02/17/22 - Ronnie Flathers @ropnop

This tool is designed to assist in quickly bruteforcing valid Active Directory accounts. It is designed to be used on an internal Windows domain with access to one of the Domain Controllers. Warning: failed Kerberos Pre-Auth counts as a failed login and WILL lock out accounts

Usage:

kerbrute [command]

<SNIP>

We can add the tool to our PATH to make it easily accessible from anywhere on the host.

Initial Enumeration of the Domain

```
dbcyph0n@htb[/htb]$ kerbrute userenum -d INLANEFREIGHT.LOCAL --dc 172.16.5.5 jsmith.tx
```

```
2021/11/17 23:01:46 > Using KDC(s):
2021/11/17 23:01:46 > 172.16.5.5:88
2021/11/17 23:01:46 > [+] VALID USERNAME: jjones@INLANEFREIGHT.LOCAL
2021/11/17 23:01:46 > [+] VALID USERNAME: sbrown@INLANEFREIGHT.LOCAL
2021/11/17 23:01:46 > [+] VALID USERNAME: tjohnson@INLANEFREIGHT.LOCAL
2021/11/17 23:01:50 > [+] VALID USERNAME: evalentin@INLANEFREIGHT.LOCAL

<SNIP>

2021/11/17 23:01:51 > [+] VALID USERNAME: sgage@INLANEFREIGHT.LOCAL
2021/11/17 23:01:51 > [+] VALID USERNAME: jshay@INLANEFREIGHT.LOCAL
2021/11/17 23:01:51 > [+] VALID USERNAME: jhermann@INLANEFREIGHT.LOCAL
2021/11/17 23:01:51 > [+] VALID USERNAME: whouse@INLANEFREIGHT.LOCAL
2021/11/17 23:01:51 > [+] VALID USERNAME: emerцер@INLANEFREIGHT.LOCAL
2021/11/17 23:01:52 > [+] VALID USERNAME: wshepherd@INLANEFREIGHT.LOCAL
2021/11/17 23:01:56 > Done! Tested 48705 usernames (56 valid) in 9.940 seconds
```

We can see from our output that we validated 56 users in the INLANEFREIGHT.LOCAL domain and it took 9.940 seconds. Now we can take these results and build a list for use in targeted password spraying attacks.

Identifying Potential Vulnerabilities

The `local system` account `NT AUTHORITY\SYSTEM` is a built-in account in Windows operating systems. It has full control over the OS and is used to run most Windows services. It is also very common for third-party services to run in the context of the `SYSTEM` account. A `SYSTEM` account on a `domain-joined` host will be able to enumerate Active Directory by impersonating domain users, which is essentially just another kind of user account. Having `SYSTEM`-level access within a domain environment is a significant privilege, often achieved by having a domain user account.

There are several ways to gain `SYSTEM`-level access on a host, including but not limited to:

- Remote Windows exploits such as MS08-067, EternalBlue, or BlueKeep.
- Abusing a service running in the context of the `SYSTEM` account, or abusing the `SeImpersonate` privileges using `Juicy Potato`. This type of attack is possible on Windows 7 and later, and is always possible with Windows Server 2019.
- Local privilege escalation flaws in Windows operating systems such as the Windows

during an evasive penetration test, adversarial assessment, or red team engagement, you are trying to mislead the defender. Tactics, and Procedures. With that in mind, **stealth** is of concern. Throwing Nmap at an entire network is not the tools we commonly use on a penetration test will trigger alarms for an educated and prepared SOC or analyst. clarify the goal of your assessment with the client in writing before it begins.

Let's Find a User

In the following few sections, we will hunt for a domain user account using techniques such as LLMNR/MDNS spoofing and password spraying. These attacks are great ways to gain a foothold but must be exercised with caution and an understanding of the techniques. Now let's hunt down a user account so we can move on to the next phase of our assessment. We will take the domain piece by piece and digging deep for a multitude of misconfigurations and flaws.

VPN Servers

 **Warning:** Each time you "Switch", your connection keys are regenerated and you must re-download your VPN connection file.

All VM instances associated with the old VPN Server will be terminated when switching to a new VPN server.

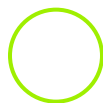
Existing PwnBox instances will automatically switch to the new VPN server.

EU Academy 4

PROTOCOL

☒ UDP 1337 ☐ TCP 443

[DOWNLOAD VPN CONNECTION FILE](#)



Connect to Pwnbox

Your own web-based Parrot Linux instance to play our labs.

Pwnbox Location

AU

Terminate Pwnbox to switch location



Questions

Answer the question(s) below to complete this Section and earn cubes!

Target(s): [Click here to spawn the target system!](#)

 SSH to with user "**htb-student**" and password "**HTB_@cademy_stdnt!**"

+ 0  From your scans, what is the "commonName" of host 172.16.5.5 ?

Submit your answer here...

+10 Streak pts

 Submit

+ 0  What host is running "Microsoft SQL Server 2019 15.00.2000.00"? (IP address, not Resolved name)

Submit your answer here...

+10 Streak pts

 Submit

 Previous

Next 

 Cheat Sheet

 Resources

Sighting In, Hunting For A User

Password Spraying Overview

-  Enumerating & Retrieving Password Policies
-  Password Spraying - Making a Target User List

Spray Responsibly

-  Internal Password Spraying - from Linux
-  Internal Password Spraying - from Windows

Deeper Down the Rabbit Hole

Enumerating Security Controls

-  Credentialed Enumeration - from Linux
-  Credentialed Enumeration - from Windows
-  Living Off the Land

Cooking with Fire

-  Kerberoasting - from Linux
-  Kerberoasting - from Windows

An ACE in the Hole

-  Access Control List (ACL) Abuse Primer
-  ACL Enumeration
-  ACL Abuse Tactics
-  DCSync

Stacking The Deck

-  Privileged Access

Kerberos "Double Hop" Problem

-  Bleeding Edge Vulnerabilities

Skill Assessment - Final Showdown

-  AD Enumeration & Attacks - Skills Assessment Part I
-  AD Enumeration & Attacks - Skills Assessment Part II
-  Beyond this Module

My Workstation

O F F L I N E

 Start Instance

 / 1 spawns left